Crimini Informatici e Sicurezza dei Computer e delle Reti

Università degli Studi di Enna "Kore"

Giovanni Giuseppe Iacuzzo - Giovanni Micciche 4 marzo 2026

Indice

1 Introduzione alla Sicurezza Informatica **2**

2 Definizioni, nomenclatura, concetti-chiave **7**

1 Introduzione alla Sicurezza Informatica

La sicurezza informatica nasce dall'esigenza imprescindibile di proteggere i dati e le comunicazioni da accessi non autorizzati, alterazioni o interruzioni. I pilastri su cui si fonda questa disciplina sono essenzialmente cinque: la riservatezza, che garantisce che l'informazione non venga intercettata da soggetti terzi; l'autenticazione, che assicura l'identità dell'interlocutore (ad esempio tramite sistemi biometrici o credenziali); l'integrità, che certifica che i dati ricevuti siano esattamente quelli trasmessi senza alcuna manipolazione; il non ripudio, che impedisce all'autore di un'operazione di negare di averla compiuta; e, infine, la disponibilità, che assicura che i servizi e i dati siano sempre accessibili e non vengano resi inservibili da attacchi, come ad esempio i Denial of Service (DoS). Per garantire integrità e non ripudio, uno degli strumenti più efficaci è la firma digitale, un sistema crittografico basato sull'uso di chiavi asimmetriche (una privata per firmare e una pubblica per verificare) che attesta in modo inequivocabile l'autenticità del mittente e la validità del documento.

Nonostante l'evoluzione dei protocolli e l'implementazione di sistemi di protezione sempre più sofisticati, il fattore umano rimane costantemente l'anello debole della catena di sicurezza. Molte delle vulnerabilità odierne non derivano da falle tecniche complesse, ma dalla pigrizia o dall'inesperienza degli utenti e degli amministratori, i quali spesso prediligono l'usabilità alla sicurezza. Quando un sistema di autenticazione risulta troppo invasivo o fastidioso, l'utente tende ad aggirarlo. A questo si aggiunge la natura intrinsecamente insicura dei protocolli di rete storici. Il protocollo Ethernet, ad esempio, essendo basato sulla trasmissione in broadcast su un canale condiviso, fa viaggiare il traffico completamente in chiaro. Chiunque si trovi nello stesso ramo di rete può utilizzare un software di sniffing come Wireshark per leggere password e dati sensibili. Similmente, protocolli obsoleti come Telnet e FTP trasmettevano informazioni non cifrate, e sono stati fortunatamente sostituiti nel tempo da standard sicuri come SSH (Secure Shell) e SFTP, che instaurano tunnel crittografati. Per proteggere ulteriormente le comunicazioni su reti pubbliche e non sicure, l'utilizzo di una VPN (Virtual Private Network) diventa fondamentale, in quanto garantisce una cifratura end-to-end che nasconde il traffico a occhi indiscreti. In ambito aziendale e privato, l'implementazione di un firewall è una contromisura di base essenziale: si tratta di un sistema (hardware o software) che filtra il traffico di rete in entrata e in uscita in base a regole di sicurezza predefinite, bloccando le connessioni sospette.

Per difendersi adeguatamente, è necessario implementare un rigoroso processo di gestione del rischio, guidato da standard internazionali come ISO, NIST e dalle direttive AgID per la Pubblica Amministrazione.

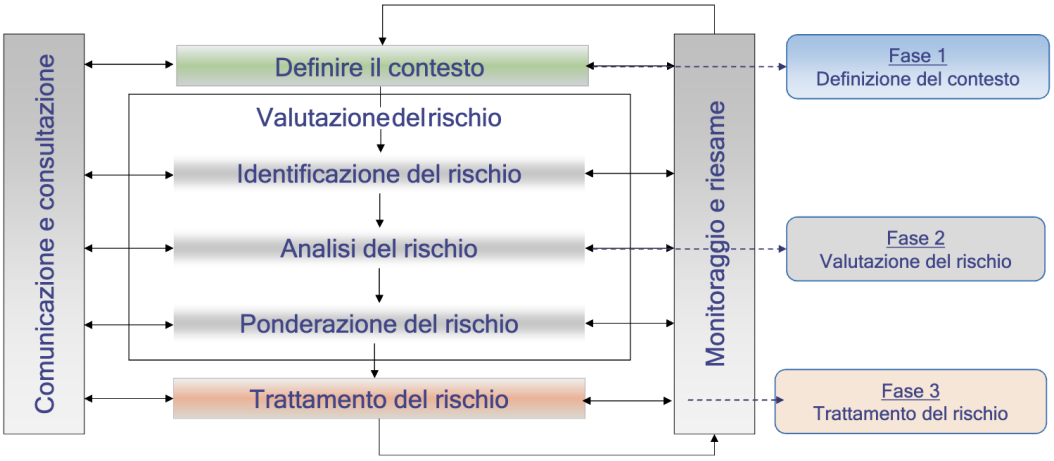

Figura 1: Framework di Cybersecurity Risk Management. Ciclo continuo e iterativo che comprende la definizione del contesto, la valutazione, il trattamento e il monitoraggio costante del rischio informatico.

Il rischio informatico, che non può mai essere azzerato, si calcola come il prodotto tra la probabilità che un attacco avvenga e l'impatto che esso avrebbe sul sistema. La probabilità dipende a sua volta dalla vulnerabilità del sistema e dal suo livello di esposizione verso l'esterno, mentre l'impatto si valuta misurando i danni arrecati alla riservatezza, all'integrità o alla disponibilità dei dati. Spesso le aziende sottovalutano questo rischio per questioni di budget, finendo per subire danni catastrofici. Gli attacchi informatici si dividono in due grandi categorie: quelli opportunistici e quelli mirati. Gli attacchi opportunistici sono casuali e automatizzati, caratterizzati da grandi volumi di traffico che scansionano la rete alla ricerca di porte aperte o dispositivi con password di default. Al contrario, gli attacchi mirati (o APT, Advanced Persistent Threat) sono estremamente silenziosi, mirano a bersagli specifici ad alto valore e iniziano sempre con una fase di OSINT (Open Source Intelligence), ovvero la raccolta metodica di informazioni pubbliche sull'infrastruttura e sui dipendenti. Sfruttando queste informazioni, gli attaccanti utilizzano tecniche di ingegneria sociale come lo spear phishing per ingannare le vittime e farle cadere in trappola. Una volta compromesso il sistema, gli obiettivi tipici includono l'esfiltrazione e la vendita di dati sensibili nel Dark Web, la cifratura dei file per richiedere un riscatto (Ransomware), o l'installazione di malware per trasformare la macchina in un bot all'interno di una rete distribuita per sferrare attacchi DDoS.

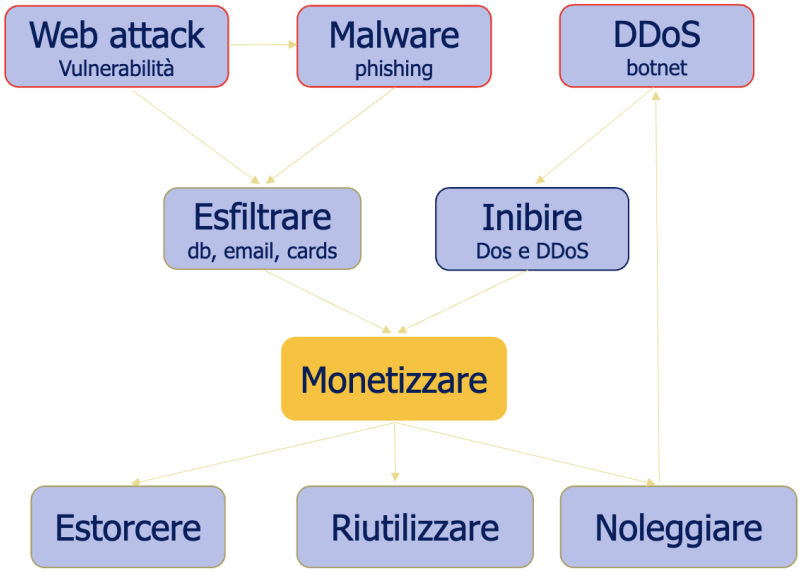

Figura 2: Flusso operativo della minaccia. Evoluzione tipica di un attacco: dai vettori di ingresso iniziali (es. Web attack o Malware tramite phishing) agli obiettivi intermedi (esfiltrazione o inibizione tramite DDoS), fino allo scopo finale di monetizzazione.

Figura 3: La struttura a iceberg del Web. Rappresentazione dei livelli Surface, Deep e Dark Web. Oggi i blackmarket per la compravendita di data leak (dati anagrafici, credenziali, carte di credito) si stanno spostando sempre più frequentemente dal Dark Web verso il Deep Web.

Analizzando il panorama attuale delle minacce, l'organizzazione OWASP evidenzia come le vulnerabilità delle applicazioni web siano il principale vettore di attacco. Sorprendentemente, le prime posizioni in classifica sono occupate da problematiche strettamente legate agli errori umani, come il Broken Access Control, che si verifica quando un utente riesce a forzare l'accesso a risorse riservate semplicemente manipolando il percorso di una URL, e le errate configurazioni di sicurezza da parte degli amministratori.

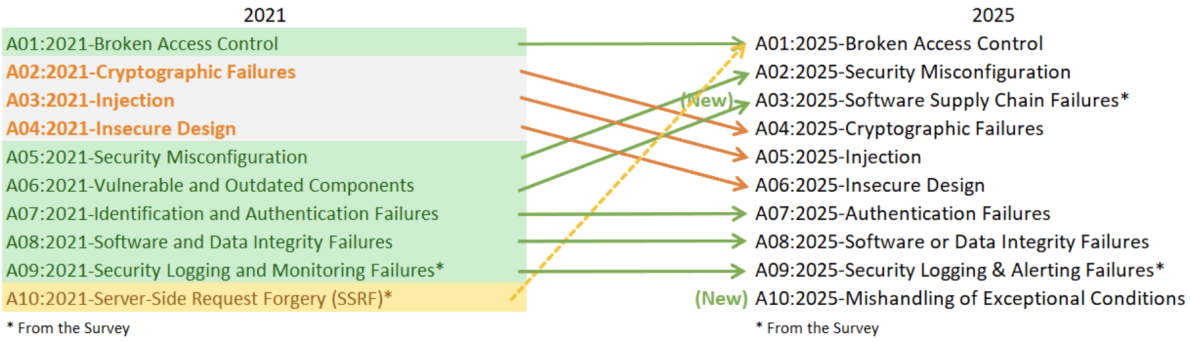

Figura 4: Classifica OWASP Top 10 (2021 vs 2025). Evoluzione delle principali vulnerabilità delle applicazioni web. Si nota in particolare l'impatto critico degli errori legati al fattore umano, come il *Broken Access Control* e la *Security Misconfiguration*.

Un classico esempio di quest'ultimo è lasciare aperta la visualizzazione dell'indice delle directory web, permettendo a chiunque di scaricare file sensibili come i backup dei database. Un altro grave pericolo deriva dall'utilizzo di componenti obsoleti: la storica vulnerabilità Heartbleed, ad esempio, sfruttava un bug nella libreria crittografica OpenSSL per sottrarre chiavi private e dati direttamente dalla memoria del server in modo del tutto invisibile.

Figura 5: Sensitive Data Exposure. Un caso pratico di vulnerabilità dovuta a un errore di configurazione: l'esposizione accidentale dell'indice di una directory riservata (`/admin/backup`), che consente il download non autorizzato di dump del database.

Un capitolo a parte meritano le cosiddette Injection e gli errori di progettazione del software. La SQL Injection è un attacco devastante che sfrutta la mancata validazione dell'input dell'utente. Se un server non filtra adeguatamente i dati inseriti in un modulo web, un attaccante può inserire caratteri speciali (come l'apice e il doppio trattino `' --`) per chiudere prematuramente la stringa legittima e commentare i controlli di sicurezza, manipolando di fatto la query eseguita sul database per estrarre tutti i record nascosti. Per prevenire questo problema, è necessario utilizzare strati software intermedi come le API e le query parametrizzate.

```
GET: https://insecure-hospital.com/progetti?categoria=covid
SQL: SELECT * FROM progetti WHERE categoria = 'covid' AND visibile = 1

visibile = 1 mostra solo i progetti che possono essere visibili al pubblico

GET: https://insecure-hospital.com/progetti?categoria=covid'--
SQL: SELECT * FROM progetti WHERE categoria = 'covid'--' AND visibile = 1

-- commento in SQL

SQL: SELECT * FROM progetti WHERE categoria = 'covid'
restituirà in output tutti i progetti, compresi quelli con flag visibile = 0
```

Figura 6: Dinamica di una SQL Injection. Alterazione di una query legittima tramite l'inserimento di input malevolo (es. l'uso del doppio trattino `'--'` per commentare il resto dell'istruzione). Ciò neutralizza le restrizioni di sicurezza (es. `visibile = 1`) e restituisce all'attaccante l'intera base dati.

Un'altra forma diffusa di iniezione di codice è il Cross-Site Scripting (XSS), tramite il quale si esegue codice JavaScript malevolo direttamente nel browser della vittima, permettendo di rubare identificatori di sessione e impersonare l'utente legittimo.

```
GET: https://insecure-hospital.com/search?text=covid
RES: <p>Search: covid</p>

GET: https://insecure-hospital.com/search?text=<script>alert(document.cookie)</script>
RES: PHPSESSID=qd66lO8djbtu823gr82c90vbt4
```

Figura 7: Cross-Site Scripting (XSS). Iniezione ed esecuzione lato client di codice JavaScript malevolo, finalizzata al furto dell'identificativo di sessione della vittima.

È importante in questo contesto chiarire il concetto di Client e Server, che il professore ha voluto sottolineare a lezione: essi non sono semplici macchine fisiche, bensì software. Un server è un programma che eroga un servizio, mentre un client è un programma che lo richiede; entrambi possono tranquillamente coesistere sullo stesso computer fisico comunicando tramite un'interfaccia di loopback locale, come accade quando si installa una suite come XAMPP per simulare un ambiente web offline. Infine, gli errori crittografici rappresentano una minaccia critica, soprattutto quando i dati vengono lasciati in chiaro a riposo. Mentre i protocolli come WPA e HTTPS cifrano i dati durante il transito, le password e le informazioni sensibili archiviate nei database devono essere obbligatoriamente cifrate o processate tramite funzioni di hash irreversibili, nonostante ciò comporti delle difficoltà tecniche per l'indicizzazione e l'ordinamento dei record all'interno dei database relazionali.

2 Definizioni, nomenclatura, concetti-chiave

La sicurezza informatica moderna parte da un presupposto strategico che affonda le sue radici nel pensiero di Sun Tzu: l'arte della guerra ci insegna a non fare affidamento sulla speranza che il nemico non attacchi, ma sulla nostra preparazione per riceverlo, rendendo la nostra posizione inattaccabile. Poiché azzerare il rischio è impossibile, l'obiettivo principale diventa la **Gestione del Rischio**.

Nel tempo, le esigenze di sicurezza sono cambiate: se tradizionalmente le informazioni venivano protette con meccanismi fisici o amministrativi, oggi le attività si sono spostate nel cyberspazio. Questo richiede la protezione non solo dei file memorizzati, ma anche dei dati durante la loro trasmissione attraverso le reti. Le definizioni formali, spesso guidate da agenzie americane come il NIST, distinguono tre livelli di complessità crescente:

- **Computer Security:** Strumenti progettati per proteggere i dati su una singola macchina e scoraggiare gli hacker.
- **Network Security:** Misure atte a proteggere i dati durante la trasmissione su reti locali.
- **Internet Security:** Misure per proteggere i dati in transito attraverso un insieme di reti interconnesse.

Il NIST (NISTIR 7298) definisce la sicurezza come l'insieme di misure che garantiscono tre aspetti fondamentali per i sistemi e le informazioni (la cosiddetta *Triade CIA* o *RID* in italiano):

- **Confidenzialità (Riservatezza):** Preservare le restrizioni autorizzate all'accesso e alla divulgazione delle informazioni, includendo la tutela della privacy.
- **Integrità:** Difendere i dati da modifiche o distruzioni improprie, garantendo anche la non ripudiabilità e l'autenticità dei dati stessi (un esempio classico è la firma digitale).
- **Availability (Disponibilità):** Assicurare un accesso tempestivo e affidabile ai dati da parte degli utenti autorizzati.

Recentemente, a questi tre pilastri sono stati affiancati altri due concetti cruciali: l'**Autenticità** (garantire che l'autore dei dati sia chi dice di essere) e l'**Accountability** (responsabilità e tracciabilità, come l'uso dei log per sapere chi ha fatto cosa e quando).

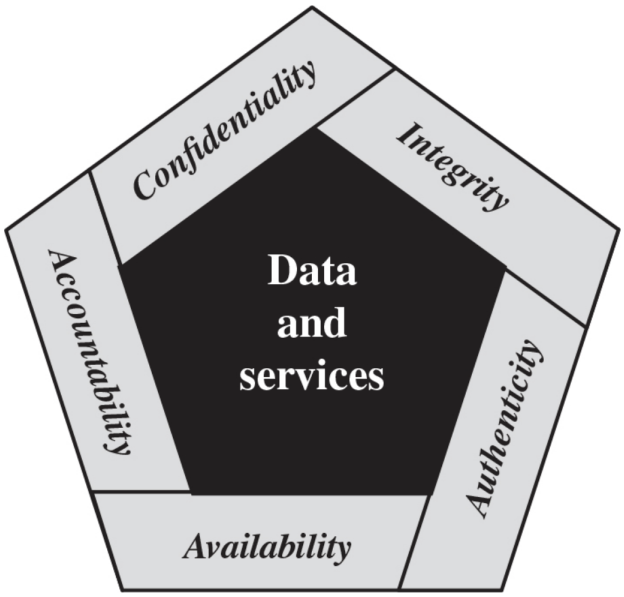

Figura 8: Estensione della Triade CIA.

Per analizzare formalmente la sicurezza, l'RFC 2828 definisce gli attori e gli elementi in gioco:

- **Asset (Risorsa):** L'oggetto della protezione. È un'entità che ha valore per l'organizzazione e può includere hardware, software, dati, infrastrutture di comunicazione, ma anche persone e strutture fisiche.
- **Minaccia (Threat):** Qualsiasi circostanza o evento potenzialmente in grado di avere un impatto negativo sulle operazioni o sugli asset dell'organizzazione.
- **Vulnerabilità:** Una debolezza nel sistema informativo o nelle procedure che può essere sfruttata da una minaccia.
- **Attacco:** L'attività malevola messa in atto dall'agente di minaccia (adversary) per tentare di distruggere, degradare o alterare le informazioni.
- **Contromisura:** Dispositivo o tecnica utilizzata per limitare o prevenire l'efficacia di un attacco, riducendo le vulnerabilità.

In questo ecosistema, gli "attaccanti" (Threat agents) desiderano abusare degli asset dando origine a minacce che incrementano il rischio; per contro, i "proprietari" (Owners) impongono contromisure per ridurre il rischio e difendere il valore dei propri asset.

Il Rischio è la misura di quanto un'entità sia minacciata ed è funzione della probabilità di occorrenza di un evento e del suo impatto. Il **Risk Management** è un processo ciclico e continuo diviso in quattro fasi:

1. **Identificazione:** Rilevare le vulnerabilità, i potenziali pericoli e le fonti di rischio (es. perdita di integrità, impersonamento).
2. **Valutazione:** Determinare quantitativamente e qualitativamente impatto e probabilità, assegnando priorità.
3. **Pianificazione:** Identificare le contromisure da applicare tramite un'analisi costi/benefici.
4. **Controllo:** Monitorare costantemente l'efficacia delle contromisure, poiché "non si può gestire ciò che non si può misurare".

Dal punto di vista matematico, la valutazione del rischio si calcola con la seguente formula:

$$R = P \times I \times E$$

Dove:

- **P (Probabilità):** La probabilità che la minaccia sfrutti una vulnerabilità.
- **I (Impatto):** La gravità del danno qualora l'attacco abbia successo. Il livello di impatto può essere classificato in *Basso*, *Moderato* o *Alto* (con effetti catastrofici).
- **E (Efficacia dei controlli):** Il valore è alto se i controlli messi in atto sono poco efficaci.

Proteggere un sistema non è affatto banale e si scontra con una serie di problematiche intrinseche:

- **Asimmetria:** Agli attaccanti basta trovare una singola vulnerabilità per avere successo, mentre i progettisti devono scovare ed eliminare tutte le debolezze per ottenere una sicurezza perfetta.
- **L'Errore Umano e l'Usabilità:** Molti utenti (e persino amministratori) percepiscono i sistemi di sicurezza rigorosi come un impedimento all'efficienza e alla facilità d'uso del sistema. L'essere umano rappresenta spesso "l'anello più debole" della catena.
- **Sicurezza come "Afterthought":** Troppo spesso la sicurezza viene aggiunta alla fine del processo di sviluppo, anziché essere integrata sin dalla fase di design.
- **Percezione del Beneficio:** Vi è una naturale tendenza a percepire un basso ritorno sull'investimento per la sicurezza... finché non si verifica un incidente e si diventa vittime. Questo si ricollega al mantra fondamentale: *"You Don't Have To Be a Target To Become a Victim"*.

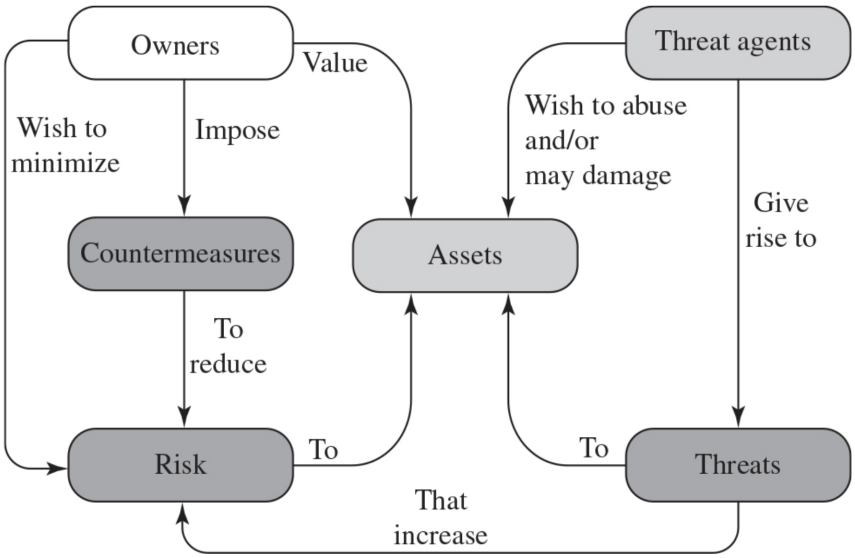

Figura 9: Flow Chart del Rischio.

La figura illustra il delicato ecosistema della sicurezza informatica, che possiamo immaginare come una continua partita a scacchi tra chi difende e chi attacca. Al centro di questo scenario troviamo gli *Asset* (le risorse), ovvero i beni preziosi a cui i proprietari (gli *Owners*) attribuiscono un grande valore. Inevitabilmente, ai vari tipi di vulnerabilità di una risorsa di sistema corrispondono le minacce che sono in grado di sfruttare tali vulnerabilità.

Sul lato destro si posizionano gli avversari: i *Threat agents*. L'agente che esegue l'attacco viene chiamato attaccante o agente che minaccia. Essi sono spinti dal desiderio di abusare o danneggiare le risorse e, con la loro presenza, danno origine alle *Threats* (Minacce). Una minaccia rappresenta un potenziale danno alla sicurezza di una risorsa. Quando questa minaccia viene effettivamente eseguita, si trasforma in un attacco (azione minatoria) e, se ha successo, porta a una violazione indesiderata della sicurezza. L'offensiva può assumere diverse forme: un attacco attivo, ovvero un tentativo di alterare le risorse del sistema o di influenzarne il funzionamento, oppure un attacco passivo, un tentativo di apprendere informazioni dal sistema, o farne uso, ma che non influisce sulle sue risorse. Inoltre, la minaccia può essere sferrata da un *insider* autorizzato (attacco interno) oppure da un *outsider* illegittimo (attacco esterno). L'azione congiunta di questi fattori fa inevitabilmente innalzare il livello di Rischio (*Risk*).

A contrapporsi a questa forza offensiva ci sono i difensori, situati sul lato sinistro dello schema. I gestori (o *Owners*) desiderano fortemente minimizzare il pericolo per le proprie risorse. Per difendersi, impongono quindi delle *Countermeasures* (Contromisure). Una contromisura è qualsiasi mezzo adottato per fronteggiare un attacco alla sicurezza. Idealmente, una contromisura può essere concepita per impedire che un particolare tipo di attacco abbia successo, ma quando la prevenzione non è possibile, l'obiettivo è quello di rilevare l'attacco e rimediare agli effetti dello stesso. Lo scopo vitale delle contromisure è, dunque, quello di ridurre il Rischio globale.

Tuttavia, il Rischio (situato nella parte inferiore del diagramma) funge da indicatore di un equilibrio puramente dinamico. Da una parte le minacce lo spingono verso l'alto, dall'altra le contromisure cercano di abbassarlo. È fondamentale ricordare che una contromisura può essa stessa introdurre nuove vulnerabilità e, a ogni modo, vulnerabilità residue potrebbero rimanere dopo il ricorso a contromisure. Tali vulnerabilità possono essere sfruttate da attaccanti e rappresentano un livello di rischio residuale per le risorse. Sarà compito continuo dei gestori cercare di minimizzare questo rischio, dati gli altri vincoli del sistema.